PUBLIC KEY INFRASTRUCTURE

S02: X.509 v3, Cấu trúc ASN.1 DER & Thẩm tra Chuỗi

Nguyen An Khuong, *CSE-HCMUT*
ORCID: 0000-0002-9910-6387 · Email: nakhuong@hcmut.edu.vn

Ho Chi Minh City University of Technology (HCMUT), VNU-HCM
Faculty of Computer Science and Engineering
Teaching Assistant: Mr. Nguyen Huu Hoang Huy (LinkedIn Profile)

Session 2 of 9 · ATHK 512 (KMA CHAT4P, HK261)
Class: Sat 10/10/2026 · 13h30–18h30
Standards: IETF RFC 5280, ITU-T X.690, CA/B Forum, ZLint

PUBLIC KEY INFRASTRUCTURE
S02: X.509 v3, Cấu trúc ASN.1 DER & Thẩm tra Chuỗi

1. Tổng quan & Chuẩn đầu ra Buổi S02

Lộ Trình Học Phần (Buổi 2/9)

S01: Architecture, Trust & Threat Models	**S02: X.509, ASN.1 & Path Validation**	S03: CA Lifecycle & ACME Protocol
S04: Revocation (CRL/OCSP) & Hardware HSM	S05: TLS 1.3 & mTLS Zero Trust Gateway	S06: Certificate Transparency (CT) Logs & Merkle Tree
S07: PQC Migration NIST FIPS 203/204	S08: Enterprise AD CS Attack & Defense	S09: Capstone Defense & Audit Synthesis

Buổi học đi sâu vào tầng biểu diễn dữ liệu nhị phân: cách một chứng chỉ số được đóng gói bằng ASN.1 DER và quy trình giải mã, kiểm tra chữ ký ở mức byte.



S2-1 · Lộ Trình Học Phần (Buổi 2/9)

[2 phút | 13h30–13h32] Giới thiệu vị trí của Buổi 2 trên bản đồ học phần. Sau khi đã nắm tổng quan kiến trúc ở S01, hôm nay chúng ta mổ xẻ cấu trúc dữ liệu cốt lõi X.509 v3.

Chuẩn Đầu Ra Buổi Học S02 (Learning Objectives)

Sau buổi h

1. **Phân tích** quy tắc đóng gói Tag-Length-Value (TLV) trong chuẩn ASN.1 DER.
2. **Mổ xẻ** toàn diện các trường dữ liệu của TBSCertificate theo RFC 5280.
3. **Thực thi** thuật toán kiểm tra chuỗi tin cậy 6 bước (Path Validation).
4. **Sử dụng** công cụ ZLint để phát hiện tự động lỗi cú pháp và vi phạm chính sách CA/B Forum.

Quy Luật Bất Biến Của Mật Mã Nhị Phân. Chữ ký số σ được tính toán trên chuỗi byte DER của TBSCertificate. Chỉ cần sai khác đúng 1 bit hoặc thừa 1 byte padding trong cấu trúc DER, toàn bộ chuỗi tin cậy sẽ sụp đổ ngay lập tức!

Chuẩn Đầu Ra Buổi Học S02 (Learning Objectives)
Sau buổi học S02, học viên làm chủ các năng lực:
1. **Phân tích** quy tắc đóng gói Tag-Length-Value (TLV) trong chuẩn ASN.1 DER.
2. **Mổ xẻ** toàn diện các trường dữ liệu của TBSCertificate theo RFC 5280.
3. **Thực thi** thuật toán kiểm tra chuỗi tin cậy 6 bước (Path Validation).
4. **Sử dụng** công cụ ZLint để phát hiện tự động lỗi cú pháp và vi phạm chính sách CA/B Forum.
Quy Luật Bất Biến Của Mật Mã Nhị Phân. Chữ ký số σ được tính toán trên chuỗi byte DER của TBSCertificate. Chỉ cần sai khác đúng 1 bit hoặc thừa 1 byte padding trong cấu trúc DER, toàn bộ chuỗi tin cậy sẽ sụp đổ ngay lập tức!

S2-2 · Chuẩn Đầu Ra Buổi Học S02 (Learning Objectives)

[3 phút | 13h32–13h35] Nhấn mạnh vai trò của tính xác định (Determinism) trong DER: Không được có sự nhập nhằng trong cách biểu diễn dữ liệu.

2. Ngôn ngữ ASN.1 & Quy tắc Mã hóa DER

Từ Định Dạng Trừu Tượng Đến Chuỗi Byte Nhị Phân

ASN.1 (Abstract Syntax Notation One):

- Ngôn ngữ đặc tả kiểu dữ liệu độc lập với phần cứng và hệ điều hành.
- Định nghĩa cấu trúc đối tượng: `SEQUENCE`, `INTEGER`, `OCTET STRING`, `BIT STRING`.

Quy Tắc Mã Hóa DER (ITU-T X.690):

- **BER:** Cho phép nhiều cách mã hóa độ dài khác nhau.
- **DER:** Quy chuẩn chặt chẽ nhất, **chỉ có duy nhất 1 cách mã hóa** cho mỗi cấu trúc (Canonical Encoding).

Beyond · Why It Matters. Nếu dùng BER (nhiều cách mã hóa), kẻ tấn công có thể thay đổi cách mã hóa độ dài mà không làm đổi dữ liệu, khiến hash thay đổi và chữ ký số bị vô hiệu hóa (hoặc khai thác Signature Malleability)!


Từ Định Dạng Trừu Tượng Đến Chuỗi Byte Nhị Phân

ASN.1 (Abstract Syntax Notation One):

- Ngôn ngữ đặc tả kiểu dữ liệu độc lập với phần cứng và hệ điều hành.
- Định nghĩa cấu trúc đối tượng: SEQUENCE, INTEGER, OCTET STRING, BIT STRING.

Quy Tắc Mã Hóa DER (ITU-T X.690):

- BER: Cho phép nhiều cách mã hóa độ dài khác nhau.
- DER: Quy chuẩn chặt chẽ nhất, chỉ có duy nhất 1 cách mã hóa cho mỗi cấu trúc (Canonical Encoding).

Beyond · Why It Matters. Nếu dùng BER (nhiều cách mã hóa), kẻ tấn công có thể thay đổi cách mã hóa độ dài mà không làm đổi dữ liệu, khiến hash thay đổi và chữ ký số bị vô hiệu hóa (hoặc khai thác Signature Malleability)!

S2-3 · Từ Định Dạng Trừu Tượng Đến Chuỗi Byte Nhị Phân

[3 phút | 13h35–13h38] Giải thích vì sao PKI bắt buộc dùng DER mà không dùng BER hay JSON/XML: Cần dạng chính tắc tuyệt đối.

Cấu Trúc Bộ Ba Tag - Length - Value (TLV)

Tag (1 Byte)
0x30: SEQUENCE
0x02: INTEGER
0x06: OID

Length (1–4 Bytes)
Dạng ngắn (< 128B)
Dạng dài ($0x80 + n$)

Value (Nội dung)
Dữ liệu nguyên thủy
hoặc các bộ TLV con lồng nhau

Ví dụ phân tích nhị phân (dumpasn1 / openssl asn1parse):
`30 82 04 2a 30 82 03 12 a0 03 02 01 02 02 10 5a ...`
- `30`: Tag SEQUENCE (hộp chứa danh sách đối tượng).
- `82 04 2a`: Length = 0x042a = 1066 bytes dữ liệu.
- `a0 03 02 01 02`: Trường `[0] EXPLICIT version` = 2 (tức phiên bản X.509 v3).



S2-4 · Cấu Trúc Bộ Ba Tag - Length - Value (TLV)

[3 phút | 13h38–13h41] Hướng dẫn học viên đọc bytecode nhị phân ASN.1 DER. Đây là kỹ năng tối quan trọng trong bài Lab 1.

3. Mổ xẻ Chi tiết Cấu trúc TBSCertificate

Cấu Trúc Các Trường Dữ Liệu Trong RFC 5280


Cấu Trúc Các Trường Dữ Liệu Trong RFC 5280

Trường Dữ Liệu	Kiểu ASN.1	Ý Nghĩa An Ninh
version	[0] EXPLICIT Version	Phiên bản (v3 để hỗ trợ extensions)
serialNumber	CertificateSerialNumber	Định danh ngẫu nhiên duy nhất do CA cấp (tối đa 20B)
signature	AlgorithmIdentifier	Thuật toán CA dùng để ký TBSCertificate
issuer	Name	Tên phân biệt của CA phát hành chứng chỉ
validity	Validity	Thời gian hiệu lực (notBefore, notAfter)
subject	Name	Tên phân biệt của thực thể được cấp chứng chỉ
subjectPublicKeyInfo	SubjectPublicKeyInfo	Khóa công khai và thuật toán tương ứng của thực thể
extensions	[3] EXPLICIT Extensions OPTIONAL	Danh sách các phần mở rộng v3

S2-5 · Cấu Trúc Các Trường Dữ Liệu Trong RFC 5280

[3 phút | 13h41–13h44] Phân tích từng trường dữ liệu. Lưu ý: Trường subjectPublicKeyInfo chứa public key của người dùng, độc lập với thuật toán ký của CA.

Hiểm Họa An Ninh Khi Thiếu Cờ Basic Constraints

Cấu hình chuẩn:

- **Root / Sub CA:** `isCA=TRUE`, `critical=TRUE`.
- **End-Entity (Server/Client):** `isCA=FALSE` hoặc không có cờ này.

Kịch bản tấn công nếu thiếu cờ:

- Hacker đăng ký chứng chỉ hợp lệ cho `attacker.com`.
- Do CA quên gán `isCA=FALSE`, hacker lấy khóa bí mật tự ký cấp chứng chỉ cho `google.com`!

Quy Tắc Sống Còn Của Thẩm Định Chuỗi

Trình duyệt web và hệ điều hành bắt buộc phải từ chối ngay lập tức bất kỳ chứng chỉ lá (End-Entity) nào tự ý ký chứng chỉ cho một thực thể khác!



S2-6 · Hiểm Họa An Ninh Khi Thiếu Cờ Basic Constraints

[3 phút | 13h44–13h47] Đây là lỗ hổng từng xảy ra trong lịch sử khi một số CA cấp phát chứng chỉ SSL có cờ isCA=TRUE cho khách hàng cá nhân.

4. Phần Mở Rộng Trọng Yếu & Kiểm Định ZLint

Subject Alternative Name (SAN) Thay Thế Common Name

- **Lịch sử:** Trước đây tên miền được ghi trong trường `Common Name (CN)` của Subject.
- **Hạn chế:** Không hỗ trợ nhiều tên miền, không phân định rõ định danh IP, DNS hay URI.
- **Quy chuẩn hiện đại:** Bắt buộc dùng phần mở rộng **Subject Alternative Name (SAN - OID: 2.5.29.17)**:

Cấu Hình SAN Trong Môi Trường Doanh Nghiệp

```
subjectAltName = @alt_names
[alt_names]
DNS.1 = kma.edu.vn
DNS.2 = *.kma.edu.vn   # Wildcard Certificate
IP.1 = 192.168.1.100
URI.1 = spiffe://kma.edu.vn/ns/prod/sa/payment
```


Subject Alternative Name (SAN) Thay Thế Common Name
Lịch sử: Trước đây tên miền được ghi trong trường Common Name (CN) của Subject.
Hạn chế: Không hỗ trợ nhiều tên miền, không phân định rõ định danh IP, DNS hay URI.
Quy chuẩn hiện đại: Bắt buộc dùng phần mở rộng Subject Alternative Name (SAN - OID: 2.5.29.17)
Cấu Hình SAN Trong Môi Trường Doanh Nghiệp
subjectAltName = @alt_names
[alt_names]
DNS.1 = kma.edu.vn
DNS.2 = *.kma.edu.vn # Wildcard Certificate
IP.1 = 192.168.1.100
URI.1 = spiffe://kma.edu.vn/ns/prod/sa/payment

S2-7 · Subject Alternative Name (SAN) Thay Thế Common Name

[3 phút | 13h47–13h50] Hướng dẫn cú pháp cấu hình OpenSSL cho SAN đa dạng: DNS, Wildcard, IP và SPIFFE URI.

Kiểm Định Tự Động Bằng Bộ Công Cụ ZLint

Beyond · Pro-Tip & Practical Command. **ZLint (ZMap Project):** Bộ kiểm tra tuân thủ mã nguồn mở viết bằng Golang, tích hợp hơn 300 luật kiểm tra tự động đối chiếu với RFC 5280 và CA/B Forum Baseline Requirements.

```
# Kiem dinh chung chi so x509 bang zlint
zlint -pretty my_certificate.pem

# Ket qua tra ve:
# - "result": "NE" (Not Eligible)
# - "result": "NA" (Not Applicable)
# - "result": "pass" (Dat chuan)
# - "result": "warn" (Canh bao khuyen nghi)
# - "result": "error" (VI PHAM NGHIEM TRONG: CA/B Forum yeu cau thu hoi!)
```



Kiểm Định Tự Động Bằng Bộ Công Cụ ZLint

Beyond · Pro-Tip & Practical Command. ZLint (ZMap Project): Bộ kiểm tra tuân thủ mã nguồn mở viết bằng Golang, tích hợp hơn 300 luật kiểm tra tự động đối chiếu với RFC 5280 và CA/B Forum Baseline Requirements.

```
# Kiem dinh chung chi so x509 bang zlint
zlint -pretty my_certificate.pem

# Ket qua tra ve:
# - "result": "NE" (Not Eligible)
# - "result": "NA" (Not Applicable)
# - "result": "pass" (Dat chuan)
# - "result": "warn" (Canh bao khuyen nghi)
# - "result": "error" (VI PHAM NGHIEM TRONG: CA/B Forum yeu cau thu hoi!)
```

S2-8 · Kiểm Định Tự Động Bằng Bộ Công Cụ ZLint

[3 phút | 13h50–13h53] Giới thiệu ZLint: Đây là công cụ các Root Store dùng để quét định kỳ toàn bộ chứng chỉ trên thế giới.

Bài Tập Tự Kiểm Tra Buổi S02

Câu Hỏi Thẩm Định Năng Lực.

1. **Câu 1:** Một chứng chỉ có trường `basicConstraints` với `isCA=TRUE` và `pathLen=0`. CA này có thể ký phát hành thêm một Intermediate CA khác được không?
   Giải đáp: KHÔNG. `pathLen=0` nghĩa là CA này chỉ được phép ký trực tiếp cho chứng chỉ lá (End-Entity), không được ký thêm bất kỳ CA cấp dưới nào.
2. **Câu 2:** Tại sao cờ `digitalSignature` trong Key Usage không thể dùng thay cho `keyCertSign`?
   Giải đáp: Để phân tách đặc quyền: Khóa dùng để ký tài liệu/dữ liệu người dùng không bao giờ được phép dùng để ký phát hành chứng chỉ số.


Bài Tập Tự Kiểm Tra Buổi S02

Câu Hỏi Thẩm Định Năng Lực.

1. Câu 1: Một chứng chỉ có trường basicConstraints với isCA=TRUE và pathLen=0. CA này có thể ký phát hành thêm một Intermediate CA khác được không?
Giải đáp: KHÔNG. pathLen=0 nghĩa là CA này chỉ được phép ký trực tiếp cho chứng chỉ lá (End-Entity), không được ký thêm bất kỳ CA cấp dưới nào.
2. Câu 2: Tại sao cờ digitalSignature trong Key Usage không thể dùng thay cho keyCertSign?
Giải đáp: Để phân tách đặc quyền: Khóa dùng để ký tài liệu/dữ liệu người dùng không bao giờ được phép dùng để ký phát hành chứng chỉ số.

S2-9 · Bài Tập Tự Kiểm Tra Buổi S02

[2 phút | 13h53–13h55] Tổng kết buổi học S02 và giao nhiệm vụ bài Lab 1 cho học viên.